تقرير فحص الثغرات

تاريخ الفحص:
١٥/١/٢٠٢٦، ٤:١٣:٠٠ م

مدة الفحص:
N/A

الصفحات المفحوصة:
0

النماذج المفحوصة:
0

4	11	2	11	0
حرجة | Critical	عالية | High	متوسطة | Medium	منخفضة | Low	معلومات | Info

HIGH

1. Missing Security Header - STRICT-TRANSPORT-SECURITY

🔗 الرابط | URL

```
/https://0a940079038ba030ceaeb20600130098.web-security-academy.net
```

📝 الوصف | DESCRIPTION

HTTP Strict Transport Security (HSTS) not set

🔍 الدليل | EVIDENCE

```
Header "strict-transport-security" not found in response
```

🛡️ طريقة الإصلاح | REMEDIATION

Set Strict-Transport-Security header with max-age of at least 31536000 (1 year)

📊 CVSS SCORE

CWE-319 | 7

📚 المراجع | REFERENCES

/https://owasp.org/www-project-secure-headers

/https://securityheaders.com

HIGH

2. SSRF - Internal Network Access

الرابط | URL

```
https://0a940079038ba030ceaeb20600130098.web-security-academy.net/filter?category=Accessories
```

الوصف | DESCRIPTION

Server-Side Request Forgery (SSRF) vulnerability in parameter "category". Server fetched internal resource successfully

الدليل | EVIDENCE

```
Pattern matched: /localhost|127\.0\.0\.1/i
```

الحمولة | PAYLOAD

```
http://127.0.0.1
```

طريقة الإصلاح | REMEDIATION

Implement URL validation with allowlists. Block internal IP ranges and cloud metadata endpoints. Use DNS resolution validation.

CVSS SCORE

CWE-918 | **7.5**

المراجع | REFERENCES

https://portswigger.net/web-security/ssrf

https://owasp.org/www-community/attacks/Server_Side_Request_Forgery

https://cheatsheetseries.owasp.org/cheatsheets/Server_Side_Request_Forgery_Prevention_Cheat_Sheet.html

HIGH

3. SSRF - Internal Network Access

الرابط | URL

```
https://0a940079038ba030ceaeb20600130098.web-security-academy.net/filter?category=Clothing%2c+shoes+and+accessories
```

الوصف | DESCRIPTION

Server-Side Request Forgery (SSRF) vulnerability in parameter "category". Server fetched internal resource successfully

الدليل | EVIDENCE

```
Pattern matched: /localhost|127\.0\.0\.1/i
```

الحمولة | PAYLOAD

```
http://127.0.0.1
```

طريقة الإصلاح | REMEDIATION

Implement URL validation with allowlists. Block internal IP ranges and cloud .metadata endpoints. Use DNS resolution validation

CVSS SCORE

CWE-918 | **7.5**

المراجع | REFERENCES

https://portswigger.net/web-security/ssrf

https://owasp.org/www-community/attacks/Server_Side_Request_Forgery

eries.owasp.org/cheatsheets/Server_Side_Request_Forgery_Prevention_Cheat_Sheet.html

HIGH

4. SSRF - Internal Network Access

الرابط | URL

```
https://0a940079038ba030ceaeb20600130098.web-security-academy.net/filter?category=Food+%26+Drink
```

الوصف | DESCRIPTION

Server-Side Request Forgery (SSRF) vulnerability in parameter "category". Server fetched internal resource successfully

الدليل | EVIDENCE

```
Pattern matched: /localhost|127\.0\.0\.1/i
```

الحمولة | PAYLOAD

```
http://127.0.0.1
```

طريقة الإصلاح | REMEDIATION

Implement URL validation with allowlists. Block internal IP ranges and cloud .metadata endpoints. Use DNS resolution validation

CVSS SCORE

CWE-918 | **7.5**

المراجع | REFERENCES

https://portswigger.net/web-security/ssrf

https://owasp.org/www-community/attacks/Server_Side_Request_Forgery

eries.owasp.org/cheatsheets/Server_Side_Request_Forgery_Prevention_Cheat_Sheet.html

HIGH

5. SSRF - Internal Network Access

🔗 الرابط | URL

```
https://0a940079038ba030ceaeb20600130098.web-security-academy.net/filter?category=Gifts
```

📝 الوصف | DESCRIPTION

Server-Side Request Forgery (SSRF) vulnerability in parameter "category". Server fetched internal resource successfully

🔍 الدليل | EVIDENCE

```
Pattern matched: /localhost|127\.0\.0\.1/i
```

💉 الحمولة | PAYLOAD

```
http://127.0.0.1
```

🛡️ طريقة الإصلاح | REMEDIATION

Implement URL validation with allowlists. Block internal IP ranges and cloud metadata endpoints. Use DNS resolution validation.

📊 CVSS SCORE

CWE-918 | **7.5**

📚 المراجع | REFERENCES

https://portswigger.net/web-security/ssrf

https://owasp.org/www-community/attacks/Server_Side_Request_Forgery

eries.owasp.org/cheatsheets/Server_Side_Request_Forgery_Prevention_Cheat_Sheet.html

HIGH

6. IDOR - Insecure Direct Object Reference

الرابط | URL

```
https://0a940079038ba030ceaeb20600130098.web-security-academy.net/product?productId=9
```

الوصف | DESCRIPTION

Potential IDOR vulnerability in parameter "productId". Different resource content accessible with modified ID.

الدليل | EVIDENCE

```
Response differs by 682 bytes when changing ID from 9 to 10
```

الحمولة | PAYLOAD

```
Original: 9, Test: 10
```

طريقة الإصلاح | REMEDIATION

Implement proper authorization checks. Use indirect references (mapping to internal IDs). Verify user has permission to access the requested resource.

CVSS SCORE

CWE-639 | **6.5**

المراجع | REFERENCES

https://portswigger.net/web-security/access-control/idor

https://owasp.org/www-project-web-security-testing-guide/latest/4-Web_Application_Security_Testing/05-Authorization_Testing/04-Testing_for_Insecure_Direct_Object_References

HIGH

7. IDOR - Insecure Direct Object Reference

الرابط | URL

```
https://0a940079038ba030ceaeb20600130098.web-security-academy.net/product?productId=14
```

الوصف | DESCRIPTION

Potential IDOR vulnerability in parameter "productId". Different resource content accessible with modified ID.

الدليل | EVIDENCE

```
Response differs by 588 bytes when changing ID from 14 to 1
```

الحمولة | PAYLOAD

```
Original: 14, Test: 1
```

طريقة الإصلاح | REMEDIATION

Implement proper authorization checks. Use indirect references (mapping to internal IDs). Verify user has permission to access the requested resource.

CVSS SCORE

CWE-639 | **6.5**

المراجع | REFERENCES

https://portswigger.net/web-security/access-control/idor

https://owasp.org/www-project-web-security-testing-guide/latest/4-Web_Application_Security_Testing/05-Authorization_Testing/04-Testing_for_Insecure_Direct_Object_References

HIGH

IDOR - Insecure Direct Object Reference .8

الرابط | URL

```
https://0a940079038ba030ceaeb20600130098.web-security-academy.net/product?productId=19
```

الوصف | DESCRIPTION

Potential IDOR vulnerability in parameter "productId". Different resource content accessible with modified ID.

الدليل | EVIDENCE

```
Response differs by 305 bytes when changing ID from 19 to 20
```

الحمولة | PAYLOAD

```
Original: 19, Test: 20
```

طريقة الإصلاح | REMEDIATION

Implement proper authorization checks. Use indirect references (mapping to internal IDs). Verify user has permission to access the requested resource.

CVSS SCORE

CWE-639 | **6.5**

المراجع | REFERENCES

https://portswigger.net/web-security/access-control/idor

https://owasp.org/www-project-web-security-testing-guide/latest/4-Web_Application_Security_Testing/05-Authorization_Testing/04-Testing_for_Insecure_Direct_Object_References

HIGH

9. IDOR - Insecure Direct Object Reference

الرابط | URL

```
https://0a940079038ba030ceaeb20600130098.web-security-academy.net/product?productId=10
```

الوصف | DESCRIPTION

Potential IDOR vulnerability in parameter "productId". Different resource content accessible with modified ID.

الدليل | EVIDENCE

```
Response differs by 160 bytes when changing ID from 10 to 11
```

الحمولة | PAYLOAD

```
Original: 10, Test: 11
```

طريقة الإصلاح | REMEDIATION

Implement proper authorization checks. Use indirect references (mapping to internal IDs). Verify user has permission to access the requested resource.

CVSS SCORE

CWE-639 | **6.5**

المراجع | REFERENCES

https://portswigger.net/web-security/access-control/idor

https://owasp.org/www-project-web-security-testing-guide/latest/4-Web_Application_Security_Testing/05-Authorization_Testing/04-Testing_for_Insecure_Direct_Object_References

HIGH

IDOR - Insecure Direct Object Reference .10

الرابط | URL

```
https://0a940079038ba030ceaeb20600130098.web-security-academy.net/product?productId=15
```

الوصف | DESCRIPTION

Potential IDOR vulnerability in parameter "productId". Different resource content accessible with modified ID.

الدليل | EVIDENCE

```
Response differs by 596 bytes when changing ID from 15 to 1
```

الحمولة | PAYLOAD

```
Original: 15, Test: 1
```

طريقة الإصلاح | REMEDIATION

Implement proper authorization checks. Use indirect references (mapping to internal IDs). Verify user has permission to access the requested resource.

CVSS SCORE

CWE-639 | **6.5**

المراجع | REFERENCES

https://portswigger.net/web-security/access-control/idor

https://owasp.org/www-project-web-security-testing-guide/latest/4-Web_Application_Security_Testing/05-Authorization_Testing/04-Testing_for_Insecure_Direct_Object_References

HIGH

11. IDOR - Insecure Direct Object Reference

الرابط | URL

```
https://0a940079038ba030ceaeb20600130098.web-security-academy.net/product?productId=20
```

الوصف | DESCRIPTION

Potential IDOR vulnerability in parameter "productId". Different resource content accessible with modified ID.

الدليل | EVIDENCE

```
Response differs by 305 bytes when changing ID from 20 to 19
```

الحمولة | PAYLOAD

```
Original: 20, Test: 19
```

طريقة الإصلاح | REMEDIATION

Implement proper authorization checks. Use indirect references (mapping to internal IDs). Verify user has permission to access the requested resource.

CVSS SCORE

CWE-639 | **6.5**

المراجع | REFERENCES

https://portswigger.net/web-security/access-control/idor

https://owasp.org/www-project-web-security-testing-guide/latest/4-Web_Application_Security_Testing/05-Authorization_Testing/04-Testing_for_Insecure_Direct_Object_References

MEDIUM

12. Missing Security Header - X-CONTENT-TYPE-OPTIONS

🔗 الرابط | URL

```
/https://0a940079038ba030ceaeb20600130098.web-security-academy.net
```

📝 الوصف | DESCRIPTION

X-Content-Type-Options header not set

🔍 الدليل | EVIDENCE

```
Header "x-content-type-options" not found in response
```

🛡️ طريقة الإصلاح | REMEDIATION

Set X-Content-Type-Options: nosniff

📊 CVSS SCORE

CWE-16 | 5

📚 المراجع | REFERENCES

/https://owasp.org/www-project-secure-headers

/https://securityheaders.com

MEDIUM

13. Missing Security Header - CONTENT-SECURITY-POLICY

🔗 الرابط | URL

```
/https://0a940079038ba030ceaeb20600130098.web-security-academy.net
```

📝 الوصف | DESCRIPTION

Content-Security-Policy header not set

🔍 الدليل | EVIDENCE

```
Header "content-security-policy" not found in response
```

🛡️ طريقة الإصلاح | REMEDIATION

Implement a strict Content Security Policy

📊 CVSS SCORE

CWE-16 | 5

📚 المراجع | REFERENCES

/https://owasp.org/www-project-secure-headers

/https://securityheaders.com

LOW

14. Missing Security Header - X-XSS-PROTECTION

URL | الرابط

```
/https://0a940079038ba030ceaeb20600130098.web-security-academy.net
```

DESCRIPTION | الوصف

X-XSS-Protection header not set (legacy but still useful)

EVIDENCE | الدليل

```
Header "x-xss-protection" not found in response
```

REMEDIATION | طريقة الإصلاح

Set X-XSS-Protection: 1; mode=block

CVSS SCORE

CWE-79 | 3

REFERENCES | المراجع

/https://owasp.org/www-project-secure-headers

/https://securityheaders.com

15. Missing Security Header - REFERRER-POLICY

LOW

الرابط | URL

```
/https://0a940079038ba030ceaeb20600130098.web-security-academy.net
```

الوصف | DESCRIPTION

Referrer-Policy header not set

الدليل | EVIDENCE

```
Header "referrer-policy" not found in response
```

طريقة الإصلاح | REMEDIATION

Set Referrer-Policy: strict-origin-when-cross-origin

CVSS SCORE

CWE-200 | 3

المراجع | REFERENCES

/https://owasp.org/www-project-secure-headers

/https://securityheaders.com

16. Missing Security Header - PERMISSIONS-POLICY

LOW

الرابط | URL

```
/https://0a940079038ba030ceaeb20600130098.web-security-academy.net
```

الوصف | DESCRIPTION

Permissions-Policy header not set

الدليل | EVIDENCE

```
Header "permissions-policy" not found in response
```

طريقة الإصلاح | REMEDIATION

Define a Permissions-Policy to control browser features

CVSS SCORE

CWE-16 | 3

المراجع | REFERENCES

/https://owasp.org/www-project-secure-headers

/https://securityheaders.com

17. XSS - potential

LOW

الرابط | URL

```
https://0a940079038ba030ceaeb20600130098.web-security-academy.net/filter?category=Accessories
```

الوصف | DESCRIPTION

"Cross-Site Scripting (XSS) vulnerability found in parameter "category

الدليل | EVIDENCE

```
<"pageheader-...
<h1>&lt;svg onload=alert(1)&gt;</h1>
<section/>
...
```

الحمولة | PAYLOAD

```
<svg onload=alert(1)>
```

طريقة الإصلاح | REMEDIATION

Implement proper input validation and output encoding. Use Content-Security-Policy .headers

CVSS SCORE

CWE-79 | **6.1**

المراجع | REFERENCES

https://portswigger.net/web-security/cross-site-scripting

/https://owasp.org/www-community/attacks/xss

eatsheetseries.owasp.org/cheatsheets/Cross_Site_Scripting_Prevention_Cheat_Sheet.html

18. XSS - potential

LOW

الرابط | URL

```
https://0a940079038ba030ceaeb20600130098.web-security-academy.net/filter?category=Clothing%2c+shoes+and+accessories
```

الوصف | DESCRIPTION

"Cross-Site Scripting (XSS) vulnerability found in parameter "category

الدليل | EVIDENCE

```
<"pageheader-...
<h1>&lt;svg onload=alert(1)&gt;</h1>
<section/>
...
```

الحمولة | PAYLOAD

```
<svg onload=alert(1)>
```

طريقة الإصلاح | REMEDIATION

Implement proper input validation and output encoding. Use Content-Security-Policy .headers

CVSS SCORE

CWE-79 | **6.1**

المراجع | REFERENCES

https://portswigger.net/web-security/cross-site-scripting

/https://owasp.org/www-community/attacks/xss

eatsheetseries.owasp.org/cheatsheets/Cross_Site_Scripting_Prevention_Cheat_Sheet.html

19. XSS - potential

LOW

الرابط | URL

```
https://0a940079038ba030ceaeb20600130098.web-security-academy.net/filter?category=Food+%26+Drink
```

الوصف | DESCRIPTION

"Cross-Site Scripting (XSS) vulnerability found in parameter "category

الدليل | EVIDENCE

```
<idden data</title...
<head/>
<body>
script src="/resources/labheader/js/labHeader.js"></scr>
...i
```

الحمولة | PAYLOAD

```
<script>alert(1)</script>
```

طريقة الإصلاح | REMEDIATION

Implement proper input validation and output encoding. Use Content-Security-Policy .headers

CVSS SCORE

CWE-79 | **6.1**

المراجع | REFERENCES

https://portswigger.net/web-security/cross-site-scripting

/https://owasp.org/www-community/attacks/xss

eatsheetseries.owasp.org/cheatsheets/Cross_Site_Scripting_Prevention_Cheat_Sheet.html

20. XSS - potential

LOW

الرابط | URL

```
https://0a940079038ba030ceaeb20600130098.web-security-academy.net/filter?category=Gifts
```

الوصف | DESCRIPTION

"Cross-Site Scripting (XSS) vulnerability found in parameter "category

الدليل | EVIDENCE

```
<idden data</title...
<head/>
<body>
script src="/resources/labheader/js/labHeader.js"></scr>
...i
```

الحمولة | PAYLOAD

```
<script>alert(1)</script>
```

طريقة الإصلاح | REMEDIATION

Implement proper input validation and output encoding. Use Content-Security-Policy .headers

CVSS SCORE

CWE-79 | **6.1**

المراجع | REFERENCES

https://portswigger.net/web-security/cross-site-scripting

/https://owasp.org/www-community/attacks/xss

eatsheetseries.owasp.org/cheatsheets/Cross_Site_Scripting_Prevention_Cheat_Sheet.html

21. Open Redirect - Potential DOM-based Redirect

LOW

الرابط | URL

```
https://0a940079038ba030ceaeb20600130098.web-security-academy.net/filter?category=Accessories
```

الوصف | DESCRIPTION

Open Redirect vulnerability in parameter "category". External URL appears in response, potential client-side redirect.

الدليل | EVIDENCE

```
External URL reflected in response
```

الحمولة | PAYLOAD

```
https://evil.com
```

طريقة الإصلاح | REMEDIATION

Validate redirect URLs against an allowlist of permitted domains. Use relative URLs only. Avoid using user-supplied URLs for redirects.

CVSS SCORE

CWE-601 | 4

المراجع | REFERENCES

https://portswigger.net/kb/issues/00500100_open-redirection-reflected

eetseries.owasp.org/cheatsheets/Unvalidated_Redirects_and_Forwards_Cheat_Sheet.html

22. Open Redirect - Potential DOM-based Redirect

LOW

الرابط | URL

```
https://0a940079038ba030ceaeb20600130098.web-security-academy.net/filter?category=Clothing%2c+shoes+and+accessories
```

الوصف | DESCRIPTION

Open Redirect vulnerability in parameter "category". External URL appears in response, potential client-side redirect.

الدليل | EVIDENCE

```
External URL reflected in response
```

الحمولة | PAYLOAD

```
https://evil.com
```

طريقة الإصلاح | REMEDIATION

Validate redirect URLs against an allowlist of permitted domains. Use relative URLs only. Avoid using user-supplied URLs for redirects.

CVSS SCORE

CWE-601 | 4

المراجع | REFERENCES

https://portswigger.net/kb/issues/00500100_open-redirection-reflected

eetseries.owasp.org/cheatsheets/Unvalidated_Redirects_and_Forwards_Cheat_Sheet.html

23. Open Redirect - Potential DOM-based Redirect

LOW

الرابط | URL

```
https://0a940079038ba030ceaeb20600130098.web-security-academy.net/filter?category=Food+%26+Drink
```

الوصف | DESCRIPTION

Open Redirect vulnerability in parameter "category". External URL appears in response, potential client-side redirect.

الدليل | EVIDENCE

```
External URL reflected in response
```

الحمولة | PAYLOAD

```
https://evil.com
```

طريقة الإصلاح | REMEDIATION

Validate redirect URLs against an allowlist of permitted domains. Use relative URLs only. Avoid using user-supplied URLs for redirects.

CVSS SCORE

CWE-601 | 4

المراجع | REFERENCES

https://portswigger.net/kb/issues/00500100_open-redirection-reflected

eetseries.owasp.org/cheatsheets/Unvalidated_Redirects_and_Forwards_Cheat_Sheet.html

24. Open Redirect - Potential DOM-based Redirect

LOW

الرابط | URL

```
https://0a940079038ba030ceaeb20600130098.web-security-academy.net/filter?category=Gifts
```

الوصف | DESCRIPTION

Open Redirect vulnerability in parameter "category". External URL appears in response, potential client-side redirect.

الدليل | EVIDENCE

```
External URL reflected in response
```

الحمولة | PAYLOAD

```
https://evil.com
```

طريقة الإصلاح | REMEDIATION

Validate redirect URLs against an allowlist of permitted domains. Use relative URLs only. Avoid using user-supplied URLs for redirects.

CVSS SCORE

CWE-601 | 4

المراجع | REFERENCES

https://portswigger.net/kb/issues/00500100_open-redirection-reflected

eetseries.owasp.org/cheatsheets/Unvalidated_Redirects_and_Forwards_Cheat_Sheet.html

CRITICAL

25. Sensitive Data Exposure - AWS Secret Key

الرابط | URL

```
/https://0a940079038ba030ceaeb20600130098.web-security-academy.net
```

الوصف | DESCRIPTION

AWS Secret Key exposed in response. This could allow unauthorized access to services.

الدليل | EVIDENCE

```
Found AWS Secret Key: href****yLab
```

طريقة الإصلاح | REMEDIATION

Remove API keys from client-side code. Use environment variables and server-side proxies.

CVSS SCORE

CWE-798 | 9

المراجع | REFERENCES

https://owasp.org/www-community/vulnerabilities/Use_of_hard-coded_password

CRITICAL

26. SQL Injection - Boolean-based Blind

الرابط | URL

```
https://0a940079038ba030ceaeb20600130098.web-security-academy.net/filter?category=Clothing%2c+shoes+and+accessories
```

الوصف | DESCRIPTION

"Boolean-based blind SQL Injection detected in parameter "category

الدليل | EVIDENCE

```
Response length difference detected: TRUE condition similar to baseline, FALSE condition differs by 1164 bytes
```

الحمولة | PAYLOAD

```
AND '1'='1 '
```

طريقة الإصلاح | REMEDIATION

.Use parameterized queries. Implement proper input validation

CVSS SCORE

CWE-89 | **9.8**

المراجع | REFERENCES

https://portswigger.net/web-security/sql-injection/blind

https://owasp.org/www-community/attacks/Blind_SQL_Injection

CRITICAL

27. SQL Injection - Boolean-based Blind

🔗 الرابط | URL

```
https://0a940079038ba030ceaeb20600130098.web-security-academy.net/filter?category=Food+%26+Drink
```

📝 الوصف | DESCRIPTION

"Boolean-based blind SQL Injection detected in parameter "category

🔍 الدليل | EVIDENCE

```
Response length difference detected: TRUE condition similar to baseline, FALSE condition differs by 1169 bytes
```

💉 الحمولة | PAYLOAD

```
AND '1'='1 '
```

🛡️ طريقة الإصلاح | REMEDIATION

.Use parameterized queries. Implement proper input validation

📊 CVSS SCORE

CWE-89 | **9.8**

📚 المراجع | REFERENCES

https://portswigger.net/web-security/sql-injection/blind

https://owasp.org/www-community/attacks/Blind_SQL_Injection

CRITICAL

28. SQL Injection - Boolean-based Blind

الرابط | URL

```
https://0a940079038ba030ceaeb20600130098.web-security-academy.net/filter?category=Gifts
```

الوصف | DESCRIPTION

"Boolean-based blind SQL Injection detected in parameter "category

الدليل | EVIDENCE

```
Response length difference detected: TRUE condition similar to baseline, FALSE condition differs by 1176 bytes
```

الحمولة | PAYLOAD

```
AND '1'='1 '
```

طريقة الإصلاح | REMEDIATION

.Use parameterized queries. Implement proper input validation

CVSS SCORE

CWE-89 | **9.8**

المراجع | REFERENCES

https://portswigger.net/web-security/sql-injection/blind

https://owasp.org/www-community/attacks/Blind_SQL_Injection

تم إنشاء هذا التقرير بواسطة ماسح الثغرات الآلي | Auto Vulnerability Scanner
© 2026 - للاستخدام الأخلاقي فقط | For Ethical Use Only